

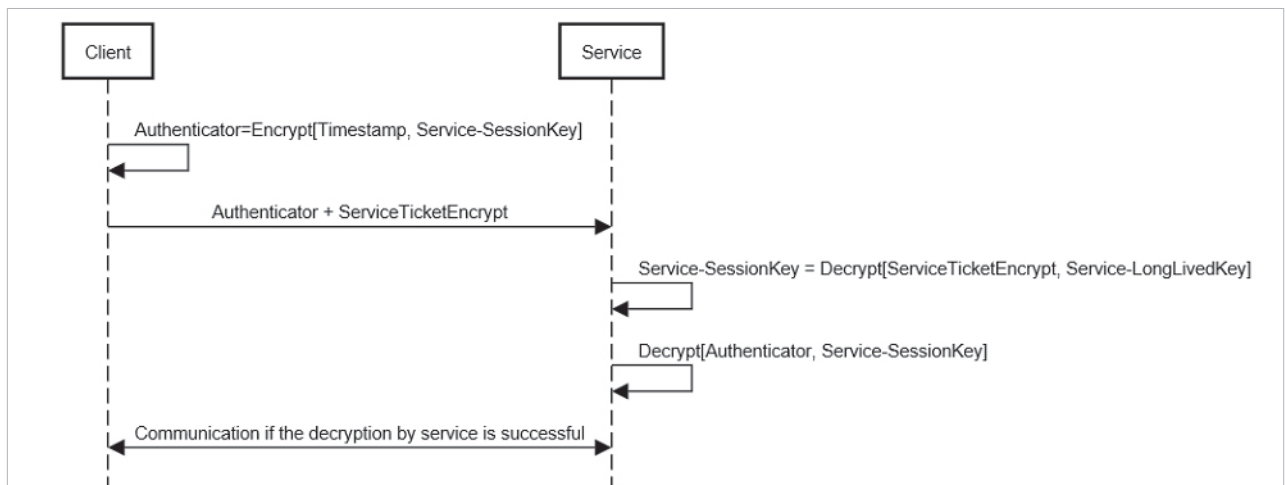


Figure 3: Client service communication

Client will have the following keys:

- Client-LongLivedKey
- TGS-SessionKey
- Service-SessionKey

Authentication server will have the following keys:

- TGS-SessionKey
- Client-LongLivedKey
- TGS-LongLivedKey

TGS component will have the following keys:

- TGS-LongLivedKey
- Service-SessionKey
- TGS-SessionKey
- Service-LongLivedKeys

Service will have the following keys:

- Service-LongLivedKeys
- Service-SessionKey

The positives of the Kerberos mechanism

- The password (Client-LongLivedKey) is never sent over the network during the authentication process.
- The client and service never authenticate mutually. With the validation of service tickets, they almost assume that they are communicating with their authentic counterpart.
- It offers enhanced security by encrypting the communication between service and client using the Service-SessionKey.

- Kerberos adds the time stamp and lifetime information for the service ticket. This has a few advantages. The first is that it limits the possibility of brute forcing and eventually cracking the encryption of the ticket. The second is that the client needs to start the authentication process all over after the ticket expiry.

The drawbacks

- The components, if running on different machines, must be time synced with each other for the expected functioning of the mechanism.
- The entire mechanism is based on the trustability of KDC; so anyone who compromises the security of KDC will essentially compromise the whole mechanism. Hence, any successful password (Client-LongLivedKey) brute force can compromise it. Multiple aspects must be considered

with respect to Kerberos security, if you want to use it in your organisation. Check the following parameters carefully and in detail before choosing it as your authentication mechanism.

- Version of Kerberos
- Ticket storing units, which may be implementation-specific
- Lifetime set in the service ticket
- Security considerations while exchanging component-specific long-lived keys

No security mechanism is 100 per cent impregnable and the same is true for Kerberos. As it has been there for long, hackers have had the opportunity to find ways around it by forging tickets, brute forcing passwords, etc. Despite this, Kerberos is considered the best security access mechanism available today. **END** 🐧

Note: This article was originally published in PenTest Magazine at <https://pentestmag.com/product/pentest-privilege-escalation-in-practice/>

References

- <https://www.youtube.com/watch?v=JkEd3pgRmuU>
- <https://www.simplilearn.com/what-is-kerberos-article>
- <https://www.varonis.com/blog/kerberos-authentication-explained/>

By: Sanjay Phanshikar

The author is a technical lead at IBM ISL, and is into information security. The focus of his work includes Web application endpoint security.